

1 Information about this chapter

IMAP or Internet Message Access Protocol allows us to access emails from a mail server. Unlike Post Office Protocol (POP3), IMAP gives us access to online management of emails directly on the server and supports folder structures. IMAP is a network protocol that allows online management of emails on a remote server and this protocol is client-server based, which makes it synchronizable for a local email client with the mailbox on the server. POP3 does not have these functionalities, it only provides listing, retrieving and deleting emails as functions. So the big difference between IMAP and POP3 is the following: when the IMAP protocol is used to read the mail, this action is done in the cloud, the email remains on the server and when the POP3 protocol is used for this action, the email is downloaded on the device doing the read action and the email is deleted from the SMTP server. Compared to SMTP, these two protocols IMAP and POP3 are mostly used for reading/deleting mails and the SMTP protocol is only used for receiving/sending emails.

2 Ports used

IMAP uses port 143 and for communication there are used text-based commands in ASCII. To be mentioned that this port is not encrypted. Alternative port for IMAP is 993 over SSL/TLS which provides encrypted communications. For POP3 ports are the following: 110 for unencrypted comms and 995 for encrypted comms, alike IMAP, over SSL/TLS.

3 Disadvantages/Flaws/Vulnerabilities

For these protocols, most vulnerabilities come out of configuration mistakes, here are some of the dangerous settings for IMAP that enabled could lead to leaking information: `auth_debug`: enables all authentication debug logging, `auth_debug_passwords`: this setting adjusts log verbosity, the submitted passwords, and the scheme gets logged, `auth_verbose`: logs unsuccessful authentication attempts and their reasons, `auth_verbose_passwords`: passwords used for authentication are logged and can also be truncated, `auth_anonymous_username`: this specifies the username to be used when logging in with the ANONYMOUS SASL mechanism. These configuration settings are mostly for IMAP because this chapter focuses mostly on this protocol, POP3 is just an alternative to it, but for POP3 protocol the configuration settings should not be too different from IMAP.

4 Usage

In order to interact with both IMAP and POP3 protocols, we can use `openssl` or `ncat`, but for this chapter we will use `openssl`:

For establishing a TLS encrypted communication over POP3 protocol

```
openssl s_client -connect <IP>:pop3s
```

For establishing a TLS encrypted communication over IMAP protocol:

```
openssl s_client -connect <IP>:imaps
```

Interactive work

1. Figure out the exact organization name from the IMAP/POP3 service and submit it as the answer.

For this to find, we will run a simple nmap to see what information we can get from there with the following command:

```
sudo nmap <IP> -sV -sC -p110,143,993,995 -T4
```

-sV for services running on the server and their version and -sC for scripts available and other information. -p110,143,993,995 these are the only ports we want to scan, pop3 and imap encrypted and unencrypted ports, -T4 for speed.

```
~ % sudo nmap [redacted] -sV -sC -p110,143,993,995 -T4 ]
[Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-31 01:27 +0300 ]
Nmap scan report for 10.129.11.165
Host is up (0.14s latency).

PORT      STATE SERVICE VERSION
110/tcp   open  pop3    Dovecot pop3d
|_pop3-capabilities: RESP-CODES CAPA SASL UIDL STLS AUTH-RESP-CODE PIPELINING TOP
| ssl-cert: Subject: commonName=dev.inlane freight.htb/organizationName=Inlane Freight Ltd/s
```

After the scan is done we can easily see the name of the organization.

Flag: InlaneFreight Ltd

2. What is the FQDN that the IMAP and POP3 servers are assigned to?

FQDN or Fully Qualified Domain Name is the complete and absolute address of a computer/server/website from a private network and it points to the exact location of that equipment in the DNS hierarchy. Executing the command that we used for question 1 we can obtain the FQDN easily from there.

```
~ % sudo nmap [redacted] -sV -sC -p110,143,993,995 -T4 ]
[Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-31 01:27 +0300 ]
Nmap scan report for 10.129.11.165
Host is up (0.14s latency).

PORT      STATE SERVICE VERSION
110/tcp   open  pop3    Dovecot pop3d
|_pop3-capabilities: RESP-CODES CAPA SASL UIDL STLS AUTH-RESP-CODE PIPELINING TOP
| ssl-cert: Subject: commonName=dev.inlane freight.htb/organizationName=Inlane Freight Ltd/s
```

Flag: dev.inlane freight.htb

3. Enumerate the IMAP service and submit the flag as the answer. (Format: HTB{...})

In order to obtain the flag for this question we will make an interaction with the server over IMAP protocol using the following command:

```
openssl s_client -connect <IP>:imaps
```

After executing this command the flag shows in the banner after the connection is established:

```
TLS session ticket lifetime hint: 7200 (seconds)
TLS session ticket:

[REDACTED]

Start Time: 1780181120
Timeout   : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0
---
read R BLOCK
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ AUTH=PLAIN] HTB{roncfbw7iszerd7shni7jr2343zhrj}
```

Flag: HTB{roncfbw7iszerd7shni7jr2343zhrj}

4. What is the customized version of the POP3 server?

This refers to the encrypted version of POP3 protocol, which is on port 995, for this we will make another interaction with the server over POP3 protocol and we will look for the information we need, most probably it will be in the banner again. Executing the following command:

```
openssl s_client -connect <IP>:pop3s
```

```
TLS session ticket lifetime hint: 7200 (seconds)
TLS session ticket:
```

```
Start Time: 1780181552
Timeout    : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
Max Early Data: 0
```

```
---
read R BLOCK
+OK InFreight POP3 v9.188
```

Again, the information we need is in the banner.

Flag: InFreight POP3 v9.188

5. What is the admin email address?

In order to find the admin email address, we will connect to the server over IMAP protocol. We use IMAP because I already checked with POP3 and there are no messages in that respective inbox over that protocol, as we mentioned, IMAP allows you to review mails on the cloud and they remain on the server, POP3 downloads them from the SMTP server and after that deletes them, they remain only locally. Use the following command in order to establish a connection with the server:

```
openssl s_client -connect <IP>:imaps
```

After that login with the following credentials: `robin:robin` (HTB provides them at the end of this chapter, they are previously used at the SMTP chapter). Commands for logging in on the IMAP server: `1 LOGIN username password`, after that, run `1 LIST "" *` in order to list all directories:

```
1 LOGIN robin robin
1 OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE SORT SORT=DISPLAY THREAD=REFERENCES THREAD=REFS THREAD=ORDEREDSUBJECT MULTIAPPEND URL-PARTIAL CATENATE UNSELECT CHILDREN NAMESPACE UIDPLUS LIST-EXTENDED I18NLEVEL=1 CONDSTORE QRESYNC ESEARCH ESORT SEARCHRES WITHIN CONTEXT=SEARCH LIST-STATUS BINARY MOVE SNIPPET=FUZZY PREVIEW=FUZZY LITERAL+ NOTIFY SPECIAL-USE] Logged in
1 LIST "" *
* LIST (\Noselect \HasChildren) "." DEV
* LIST (\Noselect \HasChildren) "." DEV.DEPARTMENT
* LIST (\HasNoChildren) "." DEV.DEPARTMENT.INT
* LIST (\HasNoChildren) "." INBOX
1 OK List completed (0.001 + 0.000 secs).
```

We select the `DEV.DEPARTMENT.INT` through the command `1 SELECT DEV.DEPARTMENT.INT` and we can see that there exists one message in this folder. Knowing that there is only 1 message in this folder, we can assume that its id is 1, so running the command `1 FETCH 1 BODY[HEADER.FIELDS (FROM)]` will give us the email's sender:

```
1 SELECT DEV.DEPARTMENT.INT
* FLAGS (\Answered \Flagged \Deleted \Seen \Draft)
* OK [PERMANENTFLAGS (\Answered \Flagged \Deleted \Seen \Draft *)] Flags permitted.
* 1 EXISTS
* 0 RECENT
* OK [UIDVALIDITY 1636414279] UIDs valid
* OK [UIDNEXT 2] Predicted next UID
1 OK [READ-WRITE] Select completed (0.001 + 0.000 secs).
```

```
1 FETCH 1 BODY[HEADER.FIELDS (FROM)]
* 1 FETCH (BODY[HEADER.FIELDS (FROM)] {42}
From: CTO <devadmin@inlanefreight.htb>
)
1 OK Fetch completed (0.001 + 0.000 secs).
```

Flag: devadmin@inlanefreight.htb

6. Try to access the emails on the IMAP server and submit the flag as the answer. (Format: HTB{...})

Keeping the connection alive from the last question, on the same folder `DEV.DEPARTMENT.INT`, we fetch the text body of the email with the following command `1 FETCH 1 BODY[TEXT]` and we get the flag:

```
1 SELECT DEV.DEPARTMENT.INT
* FLAGS (\Answered \Flagged \Deleted \Seen \Draft)
* OK [PERMANENTFLAGS (\Answered \Flagged \Deleted \Seen \Draft *)] Flags permitted.
* 1 EXISTS
* 0 RECENT
* OK [UIDVALIDITY 1636414279] UIDs valid
* OK [UIDNEXT 2] Predicted next UID
1 OK [READ-WRITE] Select completed (0.001 + 0.000 secs).
```

```
1 FETCH 1 BODY[HEADER.FIELDS (FROM)]
* 1 FETCH (BODY[HEADER.FIELDS (FROM)] {42}
From: CTO <devadmin@inlanefreight.htb>
)
1 OK Fetch completed (0.001 + 0.000 secs).
1 FETCH 1 BODY[TEXT]
* 1 FETCH (BODY[TEXT] {34}
HTB{983uzn8jmfpgpd8jmof8c34n7zio}
)
1 OK Fetch completed (0.001 + 0.000 secs).
```

Flag: HTB{983uzn8jmfpgpd8jmof8c34n7zio}